



Шифрування та РКІ (інфраструктура відкритих ключів)



Шифрування

Шифрування гарантує, що дані не можуть бути оброблені без ключа шифрування. Дешифрування може відбуватися в різних точках транзиту.

In Flight (SSL) — дані шифруються перед надсиланням і розшифровуються отримувачем. Сертифікат SSL допомагає запобігти атакам людини посередині.

Шифрування на стороні сервера — дані шифруються після отримання та розшифровуються перед надсиланням.

Шифрування на стороні клієнта — дані, зашифровані клієнтом і розшифровані одержувачем.

Ключі шифрування — шифруйте та розшифруйте дані, що надсилаються між кінцевими точками мережі (наприклад, клієнтська служба запитує інформацію з бази даних). Дані, що передаються між цими кінцевими точками, не будуть читатися, доки вони не будуть розшифровані за допомогою ключа шифрування.

Визначення PKI

Інфраструктура відкритих ключів (PKI) — це загальний термін для всього, що використовується для встановлення та керування шифруванням відкритим ключем, однією з найпоширеніших форм шифрування в Інтернеті. Він вбудований у кожен веб-браузер, який сьогодні використовується для захисту трафіку в загальнодоступному Інтернеті, але організації також можуть розгорнути його для захисту своїх внутрішніх комунікацій і доступу до підключених пристроїв.

Найважливішою концепцією PKI є, як випливає з назви, публічні криптографічні ключі, які є основою. Ці ключі не лише є частиною процесу шифрування, але й допомагають підтвердити автентичність сторін або пристроїв, які спілкуються.

Як працює PKI?

Найважливішими поняттями, які слід зрозуміти, щоб зрозуміти, як працює PKI, є ключі та сертифікати. Ключ, як уже зазначалося, — це довгий рядок бітів — іншими словами число, — який використовується для шифрування даних. Наприклад, якщо ви використали давній і простий шифр Цезаря з криптографічним ключем 3, це означало б, що кожна літера у вашому повідомленні замінюється на одну три літери далі в алфавіті — А стає D, В стає Е тощо. Щоб розшифрувати його повідомлення, ваш одержувач повинен знати не тільки те, що ви використовуєте шифр Цезаря, але й те, що ваш ключ був 3.

Очевидно, що математика, що лежить в основі сучасного шифрування, набагато складніша. Один із способів, як це відрізняється, дозволяє обійти дещо очевидну проблему з шифром Цезаря: ви повинні якимось чином повідомити одержувачу ключ, який використовується для кодування зашифрованого повідомлення.

Як працює PKI?

PKI отримав свою назву тому, що кожен учасник захищеного каналу зв'язку має два ключі. Існує відкритий ключ, який ви можете повідомити будь-кому, хто запитає, і який використовується для кодування надісланого вам повідомлення, і закритий ключ, який ви зберігаєте в секреті та використовуєте для розшифровки повідомлення, коли ви його отримуєте. Два ключі пов'язані складною математичною формулою, яку було б важко вивести за допомогою грубої сили.

Таким чином, це стосується того, як дані шифруються в інфраструктурі відкритих ключів. Але пам'ятайте, що PKI широко використовується, оскільки, окрім шифрування повідомлень, він також дозволяє вам знати, що особа, з якою ви обмінюєтеся зашифрованими повідомленнями, є тією, за кого себе видає. Ось тут і з'являються сертифікати.

Що таке сертифікати PKI?

Сертифікати PKI — це документи, які діють як цифрові паспорти, призначені будь-якій організації, яка хоче брати участь у захищеній розмові PKI. Вони можуть містити досить багато даних. Однією з найважливіших частин інформації, яку містить сертифікат, є відкритий ключ об'єкта: сертифікат є механізмом, за допомогою якого цей ключ використовується спільно. Але є також частина автентифікації. Сертифікат містить підтвердження від надійного джерела, що суб'єкт є тим, за кого себе видає. Це надійне джерело зазвичай називається **центром сертифікації (CA)**.

Що таке сертифікати PKI?

З огляду на ці концепції, це елементи, які входять до PKI.

- **Центр сертифікації**, який видає цифрові сертифікати, підписує їх власним відкритим ключем і зберігає для довідки.
- **Орган реєстрації**, який перевіряє особи тих, хто запитує цифрові сертифікати. ЦС може діяти як власний реєстраційний орган або може використовувати для цього третю сторону.
- **База даних сертифікатів**, у якій зберігаються як сертифікати, так і метадані про них, головне, період часу, протягом якого сертифікат дійсний.
- **Політика сертифікації**, що описує процедури PKI, що дозволяє стороннім судити про надійність PKI.

Як отримати сертифікат PKI

З опису цих компонентів можна побачити, що довіра є центром будь-якої інфраструктури PKI. Одна з речей, яку я роблю, коли надсилаю вам свій цифровий сертифікат, полягає в тому, щоб змусити вас повірити в те, що я є тим, за кого себе видаю, і сертифікат допомагає, оскільки за мене поручається надійна третя сторона.

Щоб зрозуміти, як це працює на практиці, давайте на мить розглянемо найпоширенішу систему інфраструктури відкритих ключів: протокол TLS/SSL, який захищає практично всі зашифровані HTTP-зв'язки.

Щоб запропонувати зв'язок із шифруванням TLS, власник веб-сайту повинен отримати сертифікат від центру сертифікації, як ми вже обговорювали. Існує велика кількість постачальників, які зареєстрували себе як центри сертифікації, і перш ніж видати вам його, вони вимагають, щоб ви певним чином підтвердили своє право власності на свій веб-сайт. Наприклад, якщо ви намагаєтеся придбати сертифікат SSL для веб-сайту на example.com, вам може знадобитися надіслати ЦС електронний лист із адреси hostmaster@example.com, тобто адреси, доступ до якої може мати особа, яка має повноваження керувати цим доменним іменем. Отримавши сертифікат, ви можете завантажити його на свій веб-сервер.

Як отримати сертифікат РКІ

Наступне очевидне питання, звичайно, полягає в тому, як ви знаєте, що можете довіряти центру сертифікації: зрештою, у випадку TLS немає централізованого органу, відповідального за стандарт, і будь-хто може встановити себе як центр сертифікації. Поганий актор у цій ролі міг би спричинити хаос. На практиці виробники ОС і браузерів, такі як Apple, Microsoft і Mozilla, є де-факто привратниками, ведучи списки довірених ЦС і заносячи в чорний список тих, хто помиляється. Рішення про те, яким центрам сертифікації довіряти, мають високі ставки, оскільки протистояння між Google і Symantec у 2017 році через те, що Google вважав слабкими стандартами Symantec, стало ясним.

Як отримати сертифікат PKI

Сертифікат SSL є, мабуть, найпоширенішим типом сертифіката PKI, який ви зустрінете в дикій природі. Але, як ми обговоримо за мить, це не єдиний вид. Інші PKI матимуть інші стандарти для видачі сертифікатів, але важливо мати на увазі, що будь-яка система PKI повинна мати певний метод, за допомогою якого центри сертифікації можуть автентифікувати користувачів, і що всі учасники системи PKI довіряють цьому методу. SSL/TLS використовує так званий ланцюжок довіри, у якому користувачі зрештою повинні вибрати довіру кореневому центру надання сертифікатів; Альтернативна схема, розроблена Finjan Cybersecurity, — це мережа довіри, у якій сертифікати користувачів підписуються іншими користувачами. Система довіри краще підходить для автономних мереж чи організацій або невеликих спільнот користувачів.

Для чого використовується PKI?

SSL може бути найпоширенішою реалізацією PKI, але точно не єдиною. Ця тема Experts Exchange містить чудовий список реальних програм PKI, зокрема:

- Надання ключа відновлення для зашифрованого жорсткого диска
- Захист внутрішніх комунікацій із серверами баз даних
- Підписання документів
- Захист локальних мереж. Можливості PKI вбудовані, наприклад, у Microsoft Active Directory і можуть працювати з фізичними картками-ключами, які зберігають цифрові сертифікати, щоб гарантувати, що користувачі є тими, за кого себе видають.
- Захищений обмін повідомленнями — наприклад, протокол Signal використовує PKI
- Шифрування електронної пошти
- Захист доступу до пристроїв Інтернету речей (IoT).

Навіщо нам PKI для безпечної електронної пошти?

PKI чудово підходить для захисту електронної пошти з тієї ж причини, що й для захисту веб-трафіку: тому що дані, що надходять через відкритий Інтернет, можна легко перехопити та прочитати, якщо вони не зашифровані, і тому, що може бути важко довіряти, що відправник – це той, за кого він себе видає, якщо немає способу автентифікувати його особу. Як ми бачили, створити майже універсальну PKI для веб-трафіку було відносно легко, оскільки більшість необхідної інфраструктури вбудовано у веб-браузери та сервери. Доступ до електронної пошти здійснюється через більш різноманітні клієнти, що робить роботу дещо складнішою.

Однією з найстаріших і найкраще налагоджених систем PKI для захисту електронної пошти є S/MIME; є також PGP (Pretty Good Privacy), який використовує модель веб-довіри, яку ми обговорювали вище. Підтримка таких видів захисту електронної пошти вбудована в такі клієнти, як Microsoft Outlook. Розвиток веб-електронної пошти в останні роки став кроком назад у цьому відношенні. Gmail, наприклад, підтримує S/MIME лише в платних облікових записах G Suite, а не в безкоштовних облікових записах.

Які ризики неналежного виконання PKI?

Наявність PKI не гарантує безпеки. Компанії іноді не вдається розгорнути або правильно керувати нею. У нещодавньому дослідженні Ponemon Institute було опитано майже 17 000 практиків у галузі IT та безпеки щодо їхніх методів керування ключами та сертифікатами. У звіті визначено найбільш значні ризики, пов'язані із захистом цифрової ідентифікації за допомогою PKI:

Час простоїв і збоїв через неправильне керування цифровими сертифікатами зростає, при цьому 73% респондентів повідомляють про інциденти, пов'язані із сертифікатами. П'ятдесят п'ять відсотків сказали, що в їхніх організаціях за останні два роки траплялося чотири або більше інцидентів.

Незахищені цифрові ідентифікатори підривають довіру. Організації використовують у середньому 88 750 ключів і сертифікатів, але лише 74% респондентів сказали, що вони знають точну кількість або термін їх дії, а 76% сказали, що відсутність захисту ключів і сертифікатів підірве довіру, необхідну їхнім організаціям для роботи. П'ятдесят дев'ять відсотків респондентів стверджують, що кіберзлочинці, які зловживають ключами та сертифікатами, посилюють потребу в їх захисті.

Які ризики неналежного виконання РКІ?

Найбільшими загрозами є невдалий аудит і компрометація ЦС. Зловмисники можуть використовувати скомпрометовані або шахрайські центри сертифікації для доставки зловмисного програмного забезпечення для здійснення атак типу "людина посередині" або фішингових атак. Аудити безпеки або відповідності можуть не виявити вразливості через невиконувану політику керування ключами або неналежну практику керування ключами.

Більше шифрування збільшує операційну складність і вартість. Дві третини респондентів додають рівні шифрування, щоб відповідати нормативним вимогам та вимогам ІТ-політики. Наприклад, 60% кажуть, що додають рівні шифрування для захисту пристроїв IoT. Це може знизити загальну ефективність бізнес-процесів, вважають 64% респондентів, а 58% кажуть, що керування більшою кількістю ключів і цифрових сертифікатів збільшує вартість.

Більшість організацій не мають ресурсів для підтримки РКІ або не призначають чіткого права власності на нього. Лише 38% респондентів сказали, що вони мають ІТ-персонал для належної підтримки РКІ. Відповідальність за РКІ з точки зору бюджету часто розподіляється по всій організації, причому найчастіше власниками є ІТ-операції (21%) і напрямки діяльності (19%). Тринадцять відсотків сказали, що відповідальність не була поділена між єдиним власником. Респонденти витрачали близько 16% свого бюджету безпеки на РКІ, або в середньому 3 мільйони доларів.

Питання та відповіді